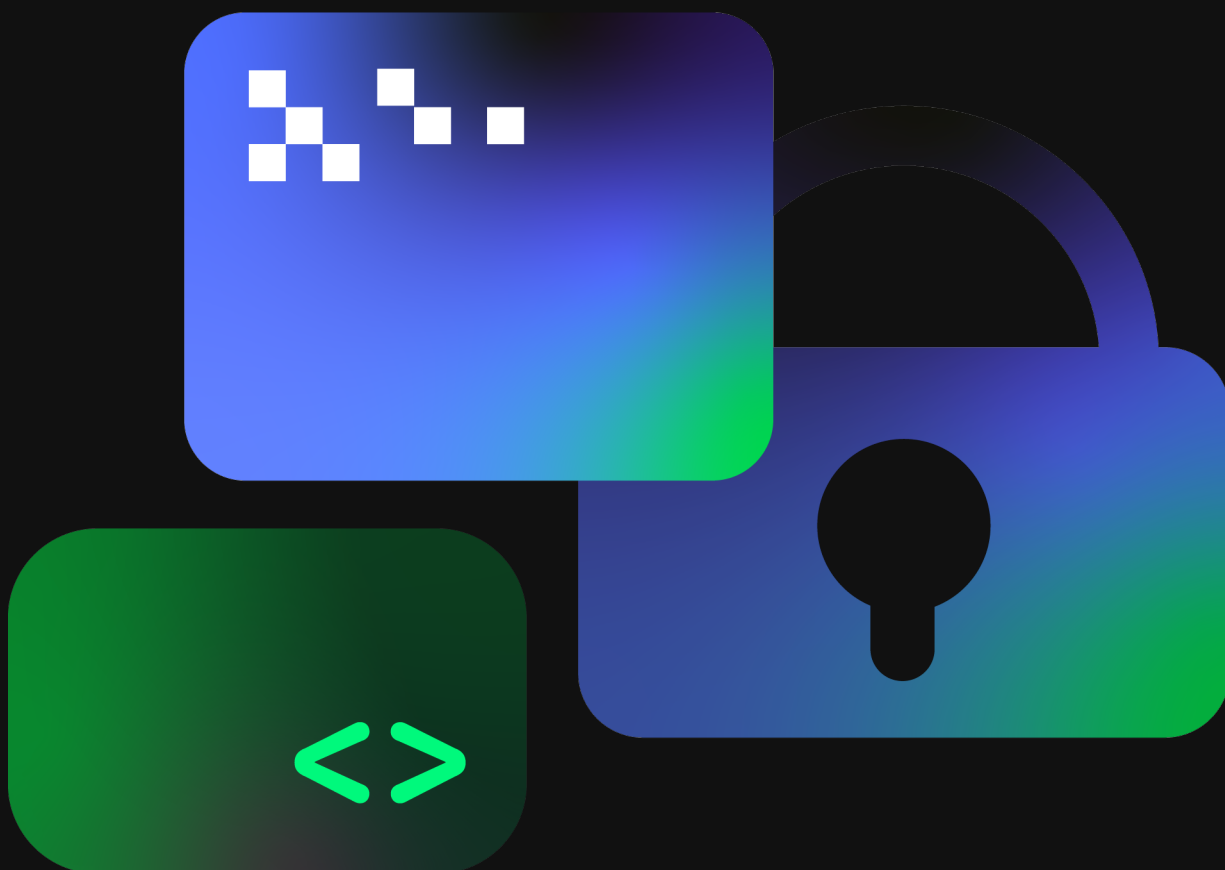




**Inter IIT Tech Meet 11.0**  
IIT Kanpur



**Saptang Labs**

● Low Prep

## **SNEAKING INTO THE CYBER-CRACKS**

The challenge will require the participants to develop a proof-of-concept exploit for the given vulnerability in a web-based application.



# OVERVIEW

The challenge will require the participants to develop a proof-of-concept exploit for the given vulnerability in a web-based application. The challenge will also test the skills of the participants in the field of information security and their ability to think creatively and critically when faced with a real-world security problem. To successfully complete the challenge, participants would need to have a good understanding of web application architecture, common attack methods, and a solid understanding of web technologies to be able to reproduce the vulnerability and develop a payload to exploit.

# OBJECTIVES

- Understand the target web application and its deployment techniques.
- Explore the application's functionality to identify potential attack surfaces.
- Analyse the impact of a successfully exploited vulnerability, including potential consequences such as data theft or unauthorised access.
- Develop a proof-of-concept exploit that demonstrates the vulnerability.
- Document the process used to exploit the vulnerability, including any tools or techniques used and present it in the form of a report and video demonstration.
- Adhere to best practices and ethical considerations in the exploit development.

**Submissions can be made till 10th February 2023, EOD.**



# EVALUATION CRITERIA

- The effectiveness of the exploit in successfully compromising the target system and executing the desired payload and the speed and ease with which it can be executed.
- The approach used to identify and exploit the vulnerability should be unique and innovative.
- The written report should provide a technical explanation of the exploit, including details on the vulnerability, the steps taken to develop the exploit, and the results obtained.
- The video demonstration should clearly show the exploit in action and provide a step-by-step explanation of the process.
- The exploit should be developed in accordance with best practices and ethical considerations in the field of information security.

# RULES

- All submissions must be original work and cannot have been submitted to any other competition or contest.
- Participants must submit a written report and a video demonstration for each of the exploits with a detailed explanation of the exploit and the steps taken to develop it. The video demonstration should clearly show the exploit in action. The reports should be submitted immediately after each vulnerability is exploited.
- A team can have up to 3 members & a member shall be a part of only one team. Collaboration between different teams is not allowed.



# LIST OF VULNERABILITIES

## 1. CVE-2022-31103 :

- lettersanitizer is a DOM-based HTML email sanitizer for in-browser email rendering. All versions of lettersanitizer below 1.0.2 are affected by a denial of service issue when processing a CSS at-rule @keyframes. This package is depended on by react-letter (<https://github.com/mat-sz/react-letter>), therefore everyone using react-letter is also at risk. The problem has been patched in version 1.0.2.

- **Base Score:** 7.5 HIGH

## 2. CVE-2022-32096 :

- Rhonabwy before v1.1.5 was discovered to contain a buffer overflow via the component r\_jwe\_aesgcm\_key\_unwrap. This vulnerability allows attackers to cause a Denial of Service (DoS) via a crafted JWE token.

- **Base Score:** 7.5 HIGH

(<https://nvd.nist.gov/vuln-metrics/cvss/v3-calculator?name=CVE-2022-32096&vector=AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H&version=3.1&source=NIST>)

## 3. CVE-2022-30524 :

- There is an invalid memory access in the TextLine class in TextOutputDev.cc in Xpdf 4.0.4 because the text extractor mishandles characters at large y coordinates. It can be triggered by (for example) sending a crafted pdf file to the pdftotext binary, which allows a remote attacker to cause a Denial of Service (Segmentation fault) or possibly have unspecified other impact.

- **Base Score:** 7.8 HIGH

(<https://nvd.nist.gov/vuln-metrics/cvss/v3-calculator?name=CVE-2022-30524&vector=AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H&version=3.1&source=NIST>)



# LIST OF VULNERABILITIES

## 4. CVE-2022-32996 :

- The django-navbar-client package of v0.9.50 to v1.0.1 was discovered to contain a code execution backdoor via the request package. This vulnerability allows attackers to access sensitive user information and digital currency keys, as well as escalate privileges.

- **Base Score:** 9.8 CRITICAL

(<https://nvd.nist.gov/vuln-metrics/cvss/v3-calculator?name=CVE-2022-32996&vector=AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H&version=3.1&source=NIST>)

## 5. CVE-2022-42699 :

- Auth. Remote Code Execution vulnerability in Easy WP SMTP plugin <= 1.5.1 on WordPress.

- **Base Score:** 8.8 HIGH

(<https://nvd.nist.gov/vuln-metrics/cvss/v3-calculator?name=CVE-2022-42699&vector=AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H&version=3.1&source=NIST>)

## 6. CVE-2022-44118 :

- dedecmdv6 v6.1.9 is vulnerable to Remote Code Execution (RCE) via file\_manage\_control.php.

- **Base Score:** 9.8 CRITICAL

(<https://nvd.nist.gov/vuln-metrics/cvss/v3-calculator?name=CVE-2022-44118&vector=AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H&version=3.1&source=NIST>)

## 7. CVE-2022-31626 :

- In PHP versions 7.4.x below 7.4.30, 8.0.x below 8.0.20, and 8.1.x below 8.1.7, when pdo\_mysql extension with mysqlnd driver, if the third party is allowed to supply host to connect to and the password for the connection, password of excessive length can trigger a buffer overflow in PHP, which can lead to a remote code execution vulnerability.

- Exploits available when we dig in

- **Base Score:** 8.8 HIGH

(<https://nvd.nist.gov/vuln-metrics/cvss/v3-calculator?name=CVE-2022-31626&vector=AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H&version=3.1&source=NIST>)